Resolute

THE SIX CONTROLS · A SELF-ASSESSMENT

Governing AI-Assisted Development

Governance for regulated engineering teams in the age of AI.
Six controls, and a scorecard for where your teams stand.

Resolute Software

Senior software consulting for regulated engineering teams

Contents

THE STATE OF PLAY

Your developers adopted AI faster than anyone governed it

The tools moved into your codebase in about two years. The governance, who signs off, how AI-written code gets tested, what an auditor would accept, is still forming in most teams we work with. The numbers below are why this playbook exists.

> **WHO THIS IS FOR**
> Engineering and security leaders in regulated or security-conscious organizations, roughly 10 to 100 developers, whose teams already use AI and now need it governed. Read it as a checklist, not a lecture, and if a control is already handled, you are ahead of most.

84%

of developers now use or plan to use AI coding tools (Stack Overflow, 2025)

45%

of AI-generated code ships a known security flaw, unchanged since 2023 (Veracode, 2026)

AI code: works vs. secure (Veracode, 2026)

Adoption is near-universal. Safe adoption is not. About 45% of AI-generated code still ships a known security flaw, and that rate has not improved in two years. Google's 2025 DORA research frames AI as an amplifier: the returns come from the system around the tool, not the tool itself. Which is another way of saying the teams that benefit and the teams that get burned are separated by governance, not tooling.

THE FRAMEWORK

Six controls that govern AI-assisted development

Each one is a place where AI either earns its speed safely or quietly creates exposure. Take them in order; the latter controls assume the former ones.

Mapped to the regimes that apply to you: EU AI Act, DORA, GDPR, NIST AI RMF, and the OWASP LLM Top 10.

01

Human ownership and sign-off

A person owns every line AI helps write.

02

Model strategy and vendor neutrality

Keep the freedom to switch models.

03

Developer platform and tooling

A short list of approved tools beats a free-for-all.

04

Quality assurance for AI-assisted code

More code, faster, needs more testing, not less.

05

Security and compliance controls

Governance you can show an auditor, not just describe.

06

Data governance

Decide what your models see before they see it.

THE SIX CONTROLS

01 Human ownership and sign-off

Principle. AI drafts; humans decide. A named person is accountable for every change an assistant helped produce, and “the model wrote it” is never a defense.

WHAT GOOD LOOKS LIKE

- Every AI-assisted change clears the same peer review and sign-off as human-written code.
- AI involvement is recorded, so you can trace what was assisted when something breaks.
- Developers stay accountable for what they merge, not for what the tool suggested.

ASK YOURSELF

> **If an auditor asked who approved a piece of AI-generated code, could you answer?**
>
> **Can you tell which commits were AI-assisted?**

Where it breaks. Reviewers treat AI output as pre-checked because it reads well, and review quality quietly drops.

MAPS TO *DORA Article 5 (governance and organisation, the management body owns the ICT-risk framework).*

THE SIX CONTROLS

02 Model strategy and vendor neutrality

Principle. Today's best model won't be next year's. An architecture that routes between models keeps you free to move, and keeps sensitive work inside your own boundary.

WHAT GOOD LOOKS LIKE

- Routing between models rather than hard-wiring one provider's SDK.
- The option to run sensitive workloads on-premises or in your own cloud.
- Model choice driven by reasoning, code quality and cost, revisited on a schedule.

ASK YOURSELF

> **If your main provider doubled its price or changed terms, how long would switching take?**
>
> **Can you route a regulated workload to a model inside your own boundary?**

Where it breaks. Everything is built against one vendor's API, and the exit cost turns out to be a rewrite.

MAPS TO *DORA Article 28 (ICT third-party risk, tested exit strategies and no vendor lock-in).*

THE SIX CONTROLS

03 Developer platform and tooling

Principle. A defined toolchain beats a free-for-all. You can only govern the tools you know about.

WHAT GOOD LOOKS LIKE

- A short list of approved assistants and IDEs, and how they connect to source control.
- Assistants configured with your context, internal libraries and standards, not just public data.
- Requirements, knowledge and documentation captured where the tools can use them.

ASK YOURSELF

> **Do you know every AI tool your developers use, or only the sanctioned ones?**
>
> **Are your assistants working from your codebase, or guessing?**

Where it breaks. Shadow tools spread, and your code, including your IP, ends up in LLMs no one approved.

THE SIX CONTROLS

04 Quality assurance for AI-assisted code

Principle. The volume of code goes up. Review and test capacity has to go up with it, or defects ship faster than before.

> **WHAT THE RESEARCH SHOWS**
> *In a 2025 controlled trial (METR), experienced developers believed AI made them about 20% faster, while measurement showed no speed-up in that setting. Perceived velocity is not measured velocity, so AI-assisted work needs the same gates as any other.*

WHAT GOOD LOOKS LIKE

- AI used to widen test creation and coverage, with humans verifying the tests are meaningful.
- Quality gates in CI that AI-assisted changes must clear like any other.
- A risk-based approach: the more sensitive the code, the more human scrutiny.

ASK YOURSELF

> **Has your test coverage kept pace with the extra code AI lets you ship?**
>
> **Do you test the AI-written tests, or trust them?**

Where it breaks. Velocity climbs, review capacity doesn't, and “almost right” code accumulates as debt.

MAPS TO *DORA Articles 24-27 (digital operational resilience testing).*

THE SIX CONTROLS

05 Security and compliance controls

Principle. Governance an examiner will accept is enforced and evidenced, not written down and hoped for.

> **WHAT THE RESEARCH SHOWS**
>
> *In Veracode's Spring 2026 tests, AI now writes syntactically correct code over 95% of the time but secure code only about 55%, so nearly half of AI-generated code carries a known flaw. Cross-site scripting is the worst: only 15% of the AI-written samples were safe.*

WHAT GOOD LOOKS LIKE

- Data boundaries enforced at runtime, not just stated in a policy.
- Audit logging and traceability for AI use across the SDLC.
- Controls mapped to what applies to you: EU AI Act, DORA and GDPR, with NIST AI RMF and the OWASP LLM Top 10 as working references.

ASK YOURSELF

> **Could you produce evidence of your AI controls for an examiner this quarter?**
>
> **Do you know which of your obligations touch AI-assisted development?**

Where it breaks. Policy exists on paper, nothing is enforced at runtime, and the gap only surfaces in an audit.

THE SIX CONTROLS

06 Data governance

Principle. Decide what data reaches a model before it does. In a regulated shop, residency and retention are set deliberately, not left to a provider's default.

> **WHAT THE RESEARCH SHOWS**
> *In a 2025 Cloud Security Alliance survey, 38% of employees admitted sharing confidential company data with AI tools their IT team had not approved.*

WHAT GOOD LOOKS LIKE

- Rules for what data can reach a model, with residency and retention set for your environment.
- Secrets and customer data kept out of prompts and logs by design.
- A clear position on how each provider's terms handle your inputs and outputs.

ASK YOURSELF

> **Where does your prompt data go, and how long does it live there?**
>
> **Would your data-protection lead sign off on your current AI tool usage?**

Where it breaks. Sensitive data leaks through prompts that no one is logging or reviewing.

SELF-ASSESSMENT

Score your own teams

Rate each control from 1 to 4. Be honest; the point is to find the gaps, not to pass.

1	2	3	4
Ad hoc	**Emerging**	**Defined**	**Governed**

1 Ad hoc, no shared practice. **2 Emerging**, inconsistent. **3 Defined**, documented, mostly followed. **4 Governed**, enforced and evidenced.

Control	Your score (1-4)
01 Human ownership and sign-off	
02 Model strategy and vendor neutrality	
03 Developer platform and tooling	
04 Quality assurance for AI-assisted code	
05 Security and compliance controls	
06 Data governance	
Total (out of 24)	

How to read your score

- **20-24, governed.** You're ahead of most. The work now is keeping it evidenced as models and teams change.
- **13-19, forming.** The pieces exist but aren't consistent or provable. Your exposure is in the gaps between them.
- **6-12, early.** AI is running ahead of your governance. Close the security, QA and data gaps before an audit or an incident does it for you.

TURN THE MAP INTO A PLAN

The framework is the easy part

Scoring yourself against six controls takes an afternoon. Running them against your actual teams, tooling and obligations, and producing something an auditor will accept, is the work. That's what we do.

The AI-in-SDLC Assessment

In under 90 days, our senior architects score your real environment, name the gaps, and hand you a governance framework and a vendor-neutral toolchain you can put in front of a board or an examiner. We delivered exactly this for First Investment Bank, a regulated European bank. Fixed scope, fixed fee, sized to your team.

Book a 30-minute scoping call: nikoleta.lazarova@resolutesoftware.com

Sources

- Stack Overflow 2025 Developer Survey - AI adoption and trust
- Veracode Spring 2026 GenAI Code Security Update
- Google 2025 DORA Report - State of AI-assisted Software Development
- METR (2025) - Impact of AI on experienced developer productivity
- Cloud Security Alliance (2025) - Shadow AI risk